コアパスワード方式の限界
～漏洩クレデンシャルに基づく定量的脆弱性評価～

宇田川 暢[1]

概要：パスワードの「コア」を固定して前後だけを変える運用は，利用者に観察され，IPA の「情報セキュリティ読本」でも紹介されている．本研究は，Collection #1（ユニークメールアドレス約 7.7 億件）のうち，異なるパスワードが 2–20 件紐づく全メールグループを用い，共通コアから残余がどの程度予測可能かを分析した．各メールグループの全パスワードからコアを抽出し，評価対象を含むコーパスで得た残余順位を同じコーパスへ適用する記述的評価では，上位 10 候補が連鎖除外後のコア共有パスワードの 15.64% を占めた．未知 1 件を模擬する LOO 評価の top-10 成功率は，残るパスワードからコアを抽出できた場合 11.35%，全対象では 1.64%であった．本研究は新たな攻撃の提案ではなく，公的に紹介される運用の条件付き危険性の定量化である．

キーワード：パスワード再利用，コアパスワード，漏洩クレデンシャル分析，パスワード推測攻撃，セキュリティ施策評価

The Limits of the Core-Password Scheme: Quantitative Vulnerability Assessment Based on Leaked Credentials

Mitsuru Udagawa[1]

Abstract: Fixing a password “core” while varying its surrounding characters is observed among users and described in an IPA security primer. We analyze all Collection #1 email groups containing 2–20 distinct passwords (from approximately 770M unique addresses) to measure residual predictability after a common core is exposed. Using cores extracted from all within-group passwords and residual rankings derived from the evaluation corpus itself, the top 10 candidates accounted for 15.64% of chain-excluded, core-sharing passwords. In leave-one-out evaluation simulating one unknown password, top-10 success was 11.35% when a core could be inferred from the remaining passwords and 1.64% over all targets. This work does not propose a new attack; it quantifies the conditional risk of a publicly described password practice.

Keywords: password reuse, core password, leaked credential analysis, password guessing attack, security policy evaluation

1. はじめに

利用者が複数のサービスで同一・類似のパスワードを使い回すことは広く知られた実態であり，その一形態として，記憶しやすい「コア」を固定し，その前後にサービスごとの短い文字列を付け足す「コアパスワード」方式がある．この種の方式は，利用者調査でも繰り返し観察されてきた [1], [2] だけでなく，公的機関による解説でも一例として紹介されている．例として，情報処理推進機構（IPA）の「情報セキュリティ読本（六訂版）」[3] では，コア（例：好みのフレーズに由来する文字列）にサービス識別子を加える形（`ringogasuki` ＋ `A-GIN` など）を，覚えやすく異なるパスワードを作る工夫として紹介し，同方式は最新の七訂版（2025 年）にも継続して紹介されている [4].

パスワードの使い回しが危険視される根本理由は，あ

[1] 研究上の所属なし
No Research Affiliation

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

るサービスから漏洩した認証情報が，同じ認証情報を用いる他サービスへの不正ログインに悪用され得る点にある [5], [6]．コアパスワード方式は，この完全な使い回しを避けつつ記憶容易性を保つ工夫であるが，固定したコアを共有する以上それも再利用の一種であり，この方式が現実の脅威環境で安全であるかは自明ではない．今日では大規模なクレデンシャル漏洩が常態化し，攻撃者が標的の同一メールアドレスに紐づく別サービスのパスワードを既に保有している可能性は十分に存在する．このとき，複数のパスワードに共通するコアが露出すれば，残りの可変部（以下，残余）の予測可能性が問題になる．すなわちコアパスワード方式は，破綻の条件を「単一漏洩」から「多重漏洩」へ引き上げるにすぎない可能性がある．本研究では「同一メールグループで，共通するコアから残余はどの程度予測可能か」を問う．これは新たな攻撃手法の提案ではなく，運用方式に内在する構造的予測可能性の定量化である．

本研究は，この問いに対して大規模漏洩データセット Collection #1[7] の主要な構造分析で答える．漏洩からの残余予測という脅威モデルは，近年のニューラルネットワークを利用した Pass2Edit[8]，PointerGuess[9] 等が既に扱っており，本研究の狙いはそれを解釈可能な構造分析として確認し，経験残余分布の集中を分析することにある．本研究の主張は，操作的定義でコア共有を検出したメールグループにおける条件付き危険性であり，個々のパスワード単独の強度や同方式の普及率を示すものではない．またデータ源は Collection #1 のため，日本の利用者に限定されない．すなわち，国内で紹介される方式の構造的危険性であって，日本人利用者の利用実態の推定ではない．

以上を踏まえ，本研究では次の 3 点を目的としている．

(1) **施策（policy）視座**：公的機関が一例として紹介する「コアパスワード」方式の構造的脆弱性を，大規模漏洩データの主要構造分析によって定量評価する．一般化した攻撃性能の追求を目的とせず，紹介内容の再考を促す実証的分析として位置づける．

(2) **解釈可能性**：カバー数優先の共通部分文字列抽出により，多重漏洩時の経験残余分布が高頻度側へ集中することを示し，先行ニューラルモデルが用いる keep/tweak 分解を統計的手法により説明可能な形で追認する．

(3) **方法論**：メールアドレス以外の追加 PII を要しない機会便乗型の攻撃者モデル，割当を無作為化して共有の非無作為性を調べる置換対照，複数パラメータの感度検証，および主要構造分析の再現可能な全件処理の方法論を与える．

2. 関連研究

本研究は，パスワード再利用の実態，推測攻撃の系譜，認証施策，国内コンテキストの各系統に位置づく．

2.1 パスワード再利用の実態

Stobert と Biddle は，利用者が少数のパスワードを改変して使い回す「パスワードのライフサイクル」を観察し [1]，Pearman らは実利用の縦断観測で再利用と部分改変を定量化した [2]．Ur らはラボでの作成観察から，多くの利用者が基底に改変を加える固有の「アルゴリズム」と，付加によって安全になるという誤解をもつことを示した [10]．日本では森らが自己申告の再利用率を 64.5%と報告している [11]．本研究はこれらの行動的知見を，大規模データ上の構造として定量化する補完に位置する．

2.2 推測攻撃の系譜

推測攻撃は Weir らの確率文脈自由文法（PCFG）[12] を起点に標的型へ発展した．Das らは複数サイト間の改変（tweaking）を体系化し [5]，以後 Wang らの TarGuess[13]，Pal らのニューラル類似度 [6]，Wang らの Pass2Edit[8]，Xiu らの PointerGuess[9]，および複数漏洩を直接扱う先行ニューラルモデルが提案されている．本研究の基本層が扱う「多重漏洩からの残余予測」という脅威モデルは，これら先行研究が既に扱っている．本研究の特長は攻撃性能の追求ではなく，PointerGuess の keep/tweak 分解と同型の「コア＋残余」分解を，学習を要しない解釈可能な統計として確認・分析する点にある．なお，共有漏洩データに混入しうる機械生成の候補列は標的型評価を過大評価させ得るが，本研究の解釈可能な分析はこれを可視化できる．

2.3 認証施策と国内コンテキスト

NIST SP800-63B-4[14] が長さとブラックリストを重視して定期変更を非推奨とし，FIDO/パスキー [15] がパスワードレス化を進める一方で，IPA「情報セキュリティ読本」[3] はコア＋識別子型を一例として紹介している．国内では，倉崎と金岡が本研究と類似した大規模漏洩データセット（通称 4iQ，14 億件規模）を分析し，日本パスワードの辞書攻撃耐性（自地域辞書で 17.72%）を示した [16]．坪根らは日本の高校「情報」教科書のパスワード作成記述を国際比較している [17]．本研究はこれら語彙・教育・施策の知見に対し，コア構造に内在する条件付きの危険性という異なる軸を扱う．

3. 脅威モデル・データ・手法

3.1 脅威モデル

本研究の想定攻撃者は，標的のメールアドレスと同一メールに紐づく漏洩パスワードを利用する日和見的攻撃者であり，氏名・住所等の追加 PII を要しない．評価は，(i) 各メールグループの全パスワードからコアを抽出し，異なるパスワードが 2–20 件紐づく主分析コーパスから得た固定残余順位を同じコーパスへ適用する記述的評価（§4，§5.2 の [A]），(ii) 未知 1 件を除く残りのパスワードからコアを

© 2026 Information Processing Society of Japan

推定し，対象メールグループの寄与を除いて再集計した残余頻度順位で未知 1 件を推測する 1 件除外（leave-one-out; LOO）評価（§5.2）からなる．推測の試行形態には，レート制限・ロックアウトの影響を受けるオンラインのログイン試行と，漏洩ハッシュに対するオフライン推測の双方がありうる．guess-number 曲線（§4.2）は試行形態に依存しない残余集中の指標であり，オンライン攻撃を想定した解釈では top-10 近傍を参照し，より多くの試行が可能なオフライン攻撃については曲線全体を参照する．

大規模なクレデンシャル漏洩は先にも述べた通り常態化しており，ハッシュ化されたパスワードであっても不適切なハッシュ方式などの場合は GPU 解析で相当数が復元されるため [18]，攻撃者が利用しうる平文パスワードの母集団は，平文での直接漏洩分にとどまらないことから，この想定は現実的なものである．

3.2 データセット

分析対象の Collection #1 は行形式や区切り文字が統一されていないため，分析用データベースを作成する前処理を施した．各行を UTF-8 へ正規化した後，タブ・コロン・セミコロン・パイプ・空白の優先順位で（メールアドレス，パスワード）対に分解し，両フィールドを trim したうえでメールアドレスを小文字化する．ハッシュ化された値（長い 16 進や PBKDF2・bcrypt・Argon2 等のプレフィックスをもつもの），区切り文字が残るパスワード（combo 形式の取りこぼし），制御文字を含むもの，空パスワード，およびメールアドレスとして解釈できない行を除外する．以後，この正規化メールアドレス単位を「メールグループ」，うち操作的定義でコアを検出したものを「コア共有グループ」と呼ぶ．メールグループは一人の利用者を表すとは限らず，各パスワードが利用されたサービスも特定できない．各除外条件を逐次適用した結果，データセットの全 2,852,051,834 行から，空行 0.094%に加え，メールとして解釈できない行 3.9%，ハッシュ様 1.9%，区切り文字残存（combo 取りこぼし）0.25%，空パスワード・制御文字・分割失敗の計 0.15% を除外し，2,673,069,454 対を得た．これを（メールアドレス，パスワード）対で重複除去した全件 DB は，1,017,085,385 ユニーク対，767,393,752 メールグループからなる．主分析用入力の生成では，さらに 256 バイトを超える 152 対を除外して 1,017,085,233 対とし，主分析範囲の抽出後に残存制御文字を含む 43 メールグループを除外した．本データは平文化済みのパスワードに偏り，強固なハッシュ運用下のサービスからの漏洩データを構造的に除外しているため，母集団はもともと脆弱な層に偏る可能性がある（この前提は §8 で留保として明示する）．なお，例示はすべて合成例とする．

合成例（例示のための架空の認証情報）．同一メールアドレス `user@example.com` に異なるパスワード 3 件が紐づくとする：

`asakura`	＝ 残余 `a` ＋ コア `sakura`
`sakura!`	＝ コア `sakura` ＋ 残余 `!`
`sakura2026`	＝ コア `sakura` ＋ 残余 `2026`

攻撃者は，既知のコア `sakura` に残余テンプレートを組み合わせ，別の未知パスワードの候補を構成できる．

図 1 コア＋残余の分解と推測の模式（合成例）
Fig. 1 Synthetic core/residual decomposition and guessing.

3.3 コア抽出と残余

以下，パスワードを PW と略す．同一メールアドレスに紐づく相異なるパスワード集合 P（要素数 n）について，全パスワード対から長さ 6–30 バイトの共通部分文字列候補を列挙・重複排除し，(i) 共通部を含むパスワード数，(ii) 共通部の候補長，(iii) 共通部の候補バイト列の昇順，の優先順位でコアを一意に選ぶ．本手法は最長優先ではなく，カバー数を優先する共通部分文字列ベースの手法である．既定の最小カバー条件は $\max(2, \lceil n/2 \rceil)$ 件，最小コア長は 6 バイトである．文字列一致はバイト単位（UTF-8）で大文字小文字・記号を区別し，残余長もバイト数で測る．同一パスワードの重複は前段で除去済みである．各パスワードについて，コアの前後に残る文字列を，その位置を保持した対（接頭・接尾）としてテンプレート化し，これを残余テンプレートと呼ぶ．同一コアが 1 件のパスワード内に複数回現れる場合は，先頭出現位置で接頭・接尾へ分割する．既知のコアにこのテンプレートを当てはめると，接頭＋コア＋接尾として元の完全パスワードが一意に復元される（したがって §4.2 の推測成功率は完全パスワードの復元率である）．以降の主結果は，純粋な累積連鎖（コアを単に伸長しただけの系列）を除外した保守的な設定によるものであり，これを含めた評価は §6 で扱う．

パラメータ依存性検証のため，最小コア長（6/5/4），累積連鎖の除外，最小カバー条件（既定の半数 $\max(2, \lceil n/2 \rceil)$，カバー率 25%/33%/50%，またはカバー数 $\max(2, \lceil \sqrt{n} \rceil)$ 件）を変え感度分析を行う（§8）．主要な構造分析は $n = 2$–20 全件に対して並列処理し，置換対照（§5.1）は $n = 2, 3, 4, 5, 10$ の各層から 30 万グループを無作為抽出した．コア・残余の分解と推測の流れを**図 1** に模式化する．

4. 基本層：残余の予測可能性

本節では，$n = 2$–20 のコア共有グループ全件について，コア既知時の残余予測可能性を定量化する．以降は最小コア長 6 バイト，最小カバー率は半数（$\max(2, \lceil n/2 \rceil)$ 件），純粋な累積連鎖を除く条件付き値であり，連鎖を含む評価は §6 で扱う．

© 2026 Information Processing Society of Japan

表 1　分析対象の構成（上 2 行：全件 DB，低 n 帯以下：主分析 TSV；字下げは下位階層）

Table 1　Analysis subsets (first two rows: full database; indented low-n rows: main-analysis TSV).

区分	グループ数	対全件	対低 n 帯
$n = 1$ (単一)	661,053,294	86.14%	—
$n \geq 2$ (複数)	106,340,458	13.86%	—
$n = 2$–20 (低 n 帯)	105,133,825	13.70%	(基準)
コア検出（連鎖除外）	12,983,221	1.69%	12.35%

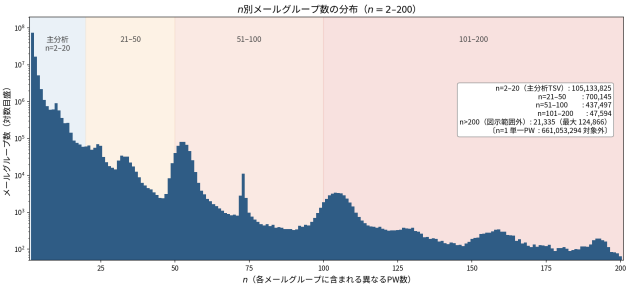


図 2　n 別メールグループ数（$n = 2$–20：主分析 TSV，$n > 20$：全件 DB）

Fig. 2　Email-group count by n ($n = 2$–20: main-analysis TSV; $n > 20$: full database).

4.1　分析対象の構成（前提）

分析対象の総ユニークメールアドレスは 767,393,752 件である．このうち単一パスワードのみ（$n = 1$）が 86.14%，複数（$n \geq 2$）が 13.86%（106,340,458 件），主分析の低 n 帯（$n = 2$–20）が 13.70%（105,133,825 件）を占める（**表 1**）．保守的な抽出定義でコア（6 バイト以上）が検出されたのは 12,983,221 グループであり，これは $n = 2$–20 の 12.35%，全体の 1.69% にあたる．連鎖を含めると 28,456,937 グループとなる．この値は，定義・分母が異なるため直接比較はできないが，編集型再利用（tweaking）を扱う先行研究 [5], [8] と同種の観測として参照できる．ただし，この構成比は方式の普及率ではない．なお，**図 2** では低 n 帯に集中する一方，$n > 20$ の局所的ピークは異なる生成過程または漏洩バッチ構成を示唆するが，原因は特定できない（§8）．$n > 200$ の 21,335 件（最大 $n = 124,866$）は図示範囲外とした．

主設定のコア共有グループ（12,983,221 件）では，選択コア長の中央値は 7 バイトであり，6–8 バイトが 10,501,857 件（80.89%），6–10 バイトが 12,299,131 件（94.73%）を占めた．

4.2　残余の guess-number 曲線（危険性の主指標）

§3.3 で定義した残余テンプレート（コアを `[CORE]` と表すと `[CORE]1`・`[CORE]123`（接尾），`a[CORE]`（接頭），`1[CORE]abc`（両側），`[CORE]`（裸のコア）のように接頭・接尾の位置を保持する）の集合について，それぞれ既知のコアに当てはめて得られる「コア＋残余」が 1 件分の完全パスワード推測に対応する．コアを既知とする攻撃者が残余テンプレートを，累積連鎖を除外したコア共有グループ（§6.2 の variation）内の頻度順（同頻度は残余キーのバイト昇順で決定的に順位付け）に試行する場合の，純粋な累積連鎖を除外した 12,983,221 件のコア共有グループに含まれるコアパスワード 43,637,223 件に対する累積推測成功率を**図 3** に示す．1 回の試行（第 1 位は空，すなわちパスワードが裸のコアそのもの）で 4.31%，10 回で 15.64%，100 回で 45.55%，1,000 回で 58.79%，10,000 回で 72.76% に達する．観測された残余テンプレートは約 510 万種類に及ぶ一方，出現割合は頻度上位の少数テンプレートに強く集中する．経験 Shannon エントロピーは，多数の希少候補の寄与も含み，少数回の推測成功率を直接表すものではない．本データでは 13.2 bit である一方，最頻候補の確率のみで定まる min-entropy は 4.54 bit（最頻候補率 4.31%）であった．本研究は Bonneau[19] に倣い，guess-number 曲線を第一指標とする．

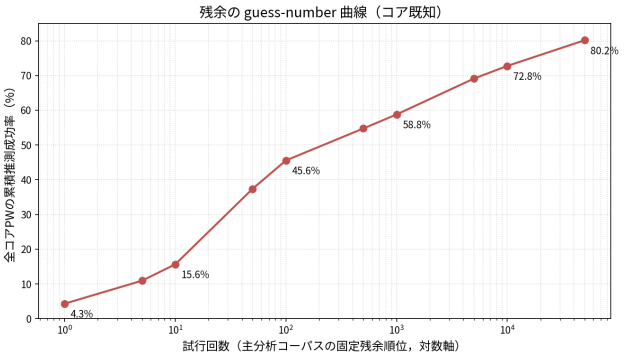


図 3　残余の guess-number 曲線（コア既知・全コアパスワードを分母とするパスワード単位の累積推測成功率）

Fig. 3　Residual guessing curve (core known; variation-specific in-sample ranking; PW-weighted).

頻度第 1 位は空であり，そのほかの上位には短い数字列や英字列を接頭・接尾に付加するテンプレートが含まれる．上位候補は，評価対象を含む主分析コーパス全体から固定した，全対象に共通のリストである（§8）．n とコア長で層別すると（**図 4**），$n = 5$・コア長 8/9/10 の固定 top-10 カバー率は 30.0/28.2/30.5%で，コア長 8 だけでも 403,314 コア PW を含む．これはパスワード単位の復元率（図 3 と同一単位）で，$n = 2$–20 主分析コーパスの全コア PW から固定した top-10 を各層へ適用した値である．§5.2 の [A] はグループ単位 best-of-n であり，分母・重みが異なり直接比較できない．各層内の条件付き値で，方式の普及率ではない．

4.3　残余の構造（弱い構造の確認）

残余長（接頭・接尾のバイト長合計）も短く，全 43,637,223

© 2026 Information Processing Society of Japan

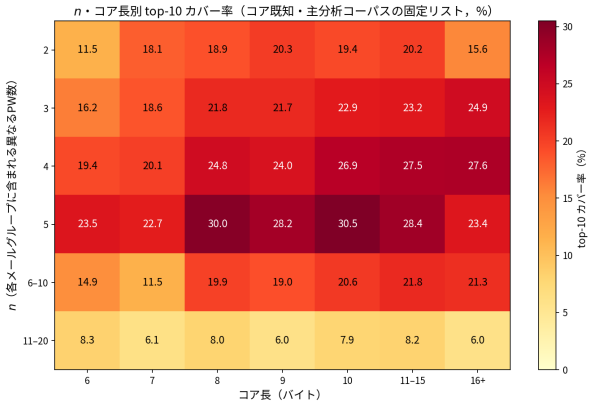


図 4 n・コア長別 top-10 カバー率（コア既知・PW 単位・主分析コーパスの固定リスト）

Fig. 4 Stratified top-10 coverage (core known; fixed in-sample ranking; PW-weighted).

コア PW のうち残余なしは 4.31%，これを含む 1 バイト以下は 42.79%，2 バイト以下は 57.96%，3 バイト以下は 73.58%であった．

残余の構造をコア前後の文字種セグメント（C ＝コア，L ＝英字，D ＝数字，S ＝記号・その他，e ＝空）で表すと，上位 20 マスクで全体の 72.2% を占める．最多マスクは接頭側に 1 英字を付す形（`L1_C_e`）で単独 23.6%に達し，以下 接尾 1 数字 `e_C_D1` 7.9%，接尾 1 英字 `e_C_L1` 5.5%，無修飾 `e_C_e` 4.3% が続く．この `L1_C_e` は，先頭への 1 英字付加であり，その一部は先頭 1 文字の大文字・小文字の切り替え（例：`Password` ↔ `password`）に対応すると解釈できる（本集計はケース変換を直接検出したものではない）．位置には非対称性があり，接尾は数字（コア直後の 1 が 12.5%），接頭は英字（接頭側 P1（コア直前）が ASCII 大文字である割合は全コア PW（43,637,223 件）比で 16.7%）に偏る．これは文字種構造が PCFG[12]，大文字化が編集型再利用 [5] の知見と整合する所見であり，一部はコア抽出規則に由来する交絡を含む（§8）．

コア前後のバイト位置別の文字種構成を**図 5** に示す．残余は主にコアに隣接する 1〜2 バイトに集中し，接尾側 S1 が数字に強く偏る一方，接頭側 P1 は英小字が主で，多くの位置は文字なしである．末尾への数字・西暦の付加は，Ur ら [10] がラボで記録した行動でもあり，本データの偏りはその行動が大規模コーパス上に残す構造的痕跡と整合する（収斂的解釈は §6.4）．

5. 妥当性：コア共有の非無作為性とコーパス内 hold-out 検証

5.1 置換（null）対照

観測されたコア共有が，単純な無作為割当でどの程度生じるかを調べるため，各メールグループに含まれる PW 数（n）と，各 PW 文字列が現れるメールグループ数を固定

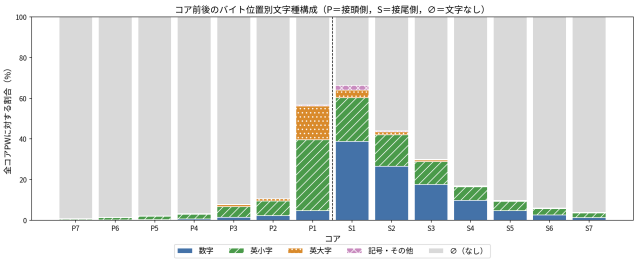


図 5 コア前後のバイト位置別文字種構成（P ＝接頭側，S ＝接尾側）

Fig. 5 Character-class composition by byte position around the core (P: prefix side, S: suffix side).

表 2 置換対照：コア検出率（実 vs 一様分布を定常目標とする Curveball MCMC の経験標本・本対照実験の標本に基づく値，分母＝各 n の標本内グループ数。null・比は置換分布の 2.5〜97.5%点（$n = 2$–5。$n = 10$ は分位点=0 で比は算定不能））

Table 2 Permutation core rate (real vs. empirical 2.5–97.5% null quantiles).

n	無作為 null (2.5〜97.5%点)	実	比 (実/null 範囲)
2	0.0073〜0.0147%	7.343%	500〜1001×
3	0.0280〜0.0417%	16.105%	387〜575×
4	0.0737〜0.0937%	25.534%	273〜347×
5	0.0010〜0.0050%	24.476%	4887〜24476×
10	0.0000〜0.0000%	76.978%	算定不能

したまま，メールグループと PW 文字列の割当を一様分布を定常目標とする Curveball MCMC[20], [21] から標本化し（各 n で 200 標本・4 chain・決定的シード），コア抽出を再実行した．無作為再割当後のコア検出率は 0.2%未満となった（**表 2**）．実データのコア検出率は，この偶然水準（置換分布の 2.5〜97.5%点）に対し $n = 2$ で 500〜1001 倍，$n = 4$ で 273〜347 倍，$n = 5$ で 4887〜24476 倍に達し，$n = 10$ では置換分布の 97.5%経験分位点が 0（ただし稀に非零標本は存在）で分位点比は算定不能となり，観測された最大 null 率に基づく記述的下限は 2.3×10^5 倍である．すなわち観測されたコア共有は，これらを固定した単純な無作為割当では説明しにくく，同一メールアドレス内の構造的依存を支持する（抽出規則由来のあらゆる偽陽性の不存在や生成原因までを証明するものではない）．

検出率は本対照の標本値であり，全データでの値は §4 を参照されたい．本対照の主眼は，無作為水準がほぼ零であることと，実データとの比率にある．標本は $n = 2, 3, 4, 5, 10$ の各層の全メールグループから固定シードで 30 万グループを無作為抽出したものであり，各グループの割当を，一様分布を定常目標とする Curveball MCMC から計 200 標本（4 chain 各 50 標本，burn-in 20・thin 2 sweep）得て置換分布を構成した（区間は type-7 経験分位点）。split-$\hat{R}$，定義可能な場合の lag-1 ESS，状態変更率，probe 多様性に顕著な異常がないことを確認したが，有限 burn-in での定常到達を保証するものではない。$n = 10$ は置換分布が

© 2026 Information Processing Society of Japan

表 3　主要な top-10 成功率の単位・分母

Table 3　Units and denominators of the principal top-10 success rates.

指標	分母・集約	成功率
§4 残余曲線	全コア PW・PW 等重み	15.64%
[A]	コア共有グループ・コア PW の最小順位	36.82%
[B]	同じ対象・全 PW の最小順位	1.89%
LOO（fold）	有効 fold・fold 等重み	11.35%
LOO（グループ）	有効 fold をもつグループ等重み	18.69%
LOO end-to-end	全 fold・fold 等重み	1.64%

ほぼ定数（検出率≒ 0）で ESS が定義不能となるため，状態変更率と probe 多様性（200/200）等の定義可能な診断で受理した．

5.2　コーパス内 hold-out 検証

残余予測をコーパス内 hold-out で検証するため，各パスワードを順次 hold-out し，残る $n-1$ 件からコアを抽出する LOO を行った．残余テンプレートの頻度順位は，対象メールグループ内の全 PW による頻度への寄与を除いて再計算した．全評価範囲 $n = 3$–20（$n = 2$ は hold-out 後 1 件となるため除外）の fold 加重条件付き成功率（コアを検出でき，hold-out にも含まれる fold を分母）は top-10 で 11.35%，top-1000 で 41.75%，グループ等重みの条件付き top-10 は 18.69%であった．全 140,219,467 fold 中，有効 fold は 20,289,669（14.47%）であり，全 fold を分母とする end-to-end 成功率は 1.64%となる．とくに $n = 10$–12（境界は結果確認後の記述的区分）は全コア PW の 24.954%を占め，全 n 共通の固定 top-10 カバー率は $n = 9$ の 15.9% から 8.7/7.9/8.2%へ，LOO 条件付き top-10 は 11.80%から 2.96/4.14/3.63%へ低下した．LOO は同一コーパス内で未知 1 件の予測を模擬する補助評価とし，主指標 [A] には，各グループの全 PW から抽出したコアと，同じコーパスから得た残余順位を用いる．[A] と，同一 $n = 2$–20 コーパスのパスワード頻度リストを使う [B] は top-10 で 36.82% と 1.89%（19.46 倍）であった．[B] は外部辞書ではない．なお §4.2 の 15.64%（図 3）は PW 単位，[A] はグループ単位 best-of-n で，分母・重みが異なり直接比較できない．各値の単位と分母を**表 3** に整理する．

[A] は「1 件以上成功」の best-of-n であるため，厳格な補助指標として，同一の固定順位で各グループのコア PW を全件復元できる割合も求めた．各グループの全 PW から抽出したコアと，同じコーパスから得た固定順位を用いる条件では，top-10 で 800,708/12,983,221 件（6.17%），top-100 で 41.32%，top-1000 で 53.47%であった．これは LOO による未知 1 件の直接予測率ではない．

各グループの全 PW から抽出したコアを固定し，残余・PW 頻度表から対象グループの全寄与だけを除いても，top-10 の [A]/[B] は 36.82%/1.89%（19.46 倍）となり，対象グループの寄与を含む元の順位を用いた結果と小数第 2 位まで一致し，top-10,000 も 92.27%/16.04%から 92.26%/16.03%への変化にとどまった．これは頻度順位における対象グループ自身の寄与のみを調べた感度分析であり，未知 PW を除いたコア推定の性能や別コーパスへの一般化を示さない．

6.　脆弱性の構造

6.1　残余分布の集中

コア既知時の脆弱性は残余の集中にある．接頭・接尾への 1 文字付加や少数桁数字が多く，`L1_C_e` 単独で 23.6%，上位 20 マスクで 72.2%に達する．コア自体の強度は本研究では定量評価しない．

コア未知時はその探索空間が残るが，多重漏洩でコアが露出すると残余だけが推測対象となる．

6.2　evolution と variation

コア共有グループは，パスワード集合の包含構造に基づき 2 類型に分かれる．variation（並列変種）は相互に包含されない分岐を含むもの，evolution（累積連鎖）は全要素が一列の入れ子を成すものである．操作的には，コア PW が部分文字列包含による全順序を成す（＝一列に入れ子に並ぶ連鎖）場合を evolution，それ以外（同長分岐・非入れ子の並列変種）を variation と判定した（$n = 2$–20 の内訳：variation 12,983,221 グループ（45.6%）・コア PW 43,637,223 件，evolution 15,473,716 グループ（54.4%）・コア PW 31,661,632 件）．両系統を分離し，同一の攻撃者（両系統の共有頻度順）に対する残余 guess-number 曲線を全件で測定した（**図 6**）．

以下の類型間差は純記述比較であり，因果効果を表さない．evolution は variation よりも大幅に予測しやすい．単発推測（裸のコアそのもの）での推測成功率は evolution が 48.86%，variation が 4.31%で 11.3 倍，共有順位の 10 回では 64.72%対 15.16%である（§4.2 の 15.64%は variation 固有順位）．これは，evolution では残余が空（パスワード＝コア）である割合が約 49%に達していることに加え，低 n（$n = 2, 3$）に集中するためである．一方 variation の残余分布は evolution より集中度が低い．両系統とも再利用脆弱性であり，evolution はより自明だが，本研究はこれを捨てず併記する．これらの主要推測成功率の 95%信頼区間（confidence interval; CI）は，メールグループを独立クラスタとみなしたモデルベースのクラスタロバスト CI（頻度ランキングは全件から固定し，その推定不確実性は含まない）で G が数千万のため全点で半幅 < 0.05 ポイントであった．ただし，この CI はメールグループ間を独立同分

© 2026 Information Processing Society of Japan

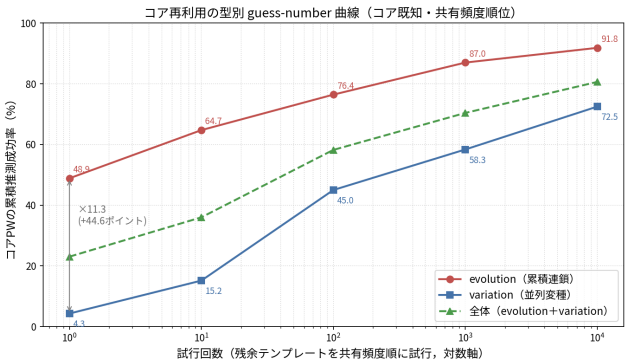


図 6 コア再利用の型別 guess-number 曲線（evolution ／ variation，共有頻度順位）

Fig. 6 By-type curves (shared in-sample ranking; PW-weighted).

布と仮定したモデル下の標本変動のみを表し，Collection #1 の母集団代表性や系統誤差は含まない（§8.3）．

6.3 identity 層：メールとの文字列関係

$n = 2$–20 のコア共有グループの 7.09%で，小文字化した localpart とコアの一方が他方の部分文字列であった（文字列の一致・包含による操作的分類であり，メールアドレスを基にコアが生成されたことを示すものではない）．内訳は完全一致 0.46%，コア ⊂ localpart 6.51%，逆包含 0.12%で，メールのみから一意に定まるのは完全一致に限る（コア長 16 以上では 17.52%）．これはサービス識別子層（§7）とは別である．

6.4 行動研究との収斂

これらの構造的規則性は，利用者の改変行動と整合する可能性がある．Ur ら [10]（§2.1）がラボで観察した基底への小改変・末尾数字/西暦・サイト名の組込みと，本研究が $n = 2$–20 全件で観測した構造（コア共有・接尾＝数字/西暦・接頭側 P1 の ASCII 大文字）は整合し，§5 の「コア共有は偶然の数百〜数千倍」という結果に対する一つの解釈を与える．ただし漏洩データは構造のみを示し意図を直接実証せず，母集団も異なるため，厳密な再現ではなく定性的な収斂的証拠として提示する（構造的規則性は他の生成過程からも部分的に生じうる）．

7. 強化層：サービス識別子

Ur ら [10] は，共通の基底文字列にサイト名の略称・変形を組み合わせる生成規則を観察した．このような規則が既知なら，「コア＋サービス識別子」型の残余候補は対象サービス名から絞り込むことが可能となる．各グループの全 PW から抽出したコアに基づく集計では，$n = 2$–20・連鎖除外コア共有グループのうち 87,646 件（0.6751%）が，接頭と接尾を連結した残余について，大小文字を無視して省略可能な@，英数字で始まる英数字・ピリオド・下線・ハイフン列，ピリオド，2 字以上の英字に完全一致する「ドメイン様」残余を 1 件以上もった．ただし，サービス出自ラベルを欠くため，これらが実際にサービス識別子として用いられた割合は測定できない．

8. 考察：施策含意・頑健性・限界

8.1 施策含意

コアパスワード方式の紹介には，本研究が示す条件付き危険性への慎重さが必要である．各グループの全 PW から抽出したコアと，同じコーパスから得た残余順位を用いるグループ単位指標 [A] は，同一コーパスの PW 辞書 [B] の 19.46 倍だが，未知 1 件を hold-out した LOO の条件付き top-10 成功率は 11.35%（全 fold を分母とすると 1.64%）である．$n = 5$・コア長 8–10 層の PW 単位 top-10 カバー率は 28.2–30.5%で，コア共有グループの約 7%はメール localpart との一致・包含関係をもち，完全一致は 0.46%である．構成規則より長さとブラックリストを重視する NIST SP800-63B-4 の方向と乖離しており，パスワード管理ツールの助けを借りて，サービスごとに独立・ランダムなパスワードを利用することが望ましい．

8.2 頑健性

最小コア長・累積連鎖の包含・検出閾値を変えると対象メールグループも異なる構成となるが，各設定で，各グループの全 PW から抽出したコアと，同じコーパスから得た残余順位を用いる [A] は，同一コーパスの PW 辞書 [B] を一貫して上回った（累積連鎖包含を除き約 9–19 倍，**表 4**）．累積連鎖を含む設定では [A] が 71.94% に上昇するが，これは evolution に通常（選択コアの候補長 30 バイト上限に掛からない連鎖で）みられる空残余（PW ＝コア）による自明成分であり，空残余を攻撃候補から除くと [A] の top-10 は 31.37%（基準の空残余除外 30.28% に近い水準）に戻る．検出閾値を緩めると [B] が上がり，倍率は低下した．

8.3 限界

本研究には次の留保がある．(i) データは漏洩・平文化パスワードに偏り母集団が弱い層に偏在しうる．さらに前処理により，文字種・空白分布はフィルタ後の条件付き分布となる．(ii) 最小カバー率にはコア共有の強いグループを選ぶ効果があり，共通部分文字列の検出は方式の意図的採用を示さない．(iii)「コア長が長いほど残余が短い」の一部はコア抽出規則による交絡である．(iv) 主範囲内の $n = 10$–12 を含め n により異なるパターンをとり，高 n の局所ピークも生成原因を特定できないため，$n = 2$–20 集約値は複数層の混合として解釈する．(v) ドメイン様残余がサービス識別子に由来する割合は測定不能（§7）．(vi)

© 2026 Information Processing Society of Japan

表 4　主要結果の感度分析（グループ単位 best-of-n，top-10．[A] = 各グループの全 PW から抽出したコア＋同一コーパスの残余順位，[B] =同一コーパスの PW 辞書）

Table 4　Sensitivity of [A]/[B] (mail-group best-of-n top-10; [A] cores use all within-group PWs; rankings use the evaluation corpus).

設定	[A]	[B]	[A]/[B]
基準（コア長 6・カバー率 50%）	36.82%	1.89%	19.46
累積連鎖を含む	71.94%	2.42%	29.71
最小コア長 5	33.70%	2.06%	16.38
最小コア長 4	26.66%	2.13%	12.50
最小カバー率 33%	38.41%	3.84%	9.99
最小カバー率 25%	38.75%	4.35%	8.91
最小カバー数 $\lceil\sqrt{n}\rceil$	39.16%	4.14%	9.45

[A]/[B] の頻度順位は評価対象を含む同一コーパスから得た．LOO では評価対象 PW をコア抽出から，対象グループの全 PW による寄与を残余頻度順位から除外したが，これも同一コーパス内の評価であり，別コーパスへの一般化を示さない．(vii) データ源は Collection #1 であり（主要構造分析は $n = 2$–20 全件），主張は国内で紹介される方式の構造的危険性であって日本人の実態推定ではない（§1）．(viii) 本データは匿名アップロードサイトで共有された Collection #1 で，MEGA のオリジナル [7] の未改変コピーである保証はない．(ix) サービス出自ラベルを欠くため，サービス横断の再利用か同一サービス内の変更・再漏洩かを判別できず，本評価は複数漏洩レコード間の構造的予測可能性であって未知サービスへの攻撃成功率の直接推定ではない（§3.1）．

9. まとめ

本研究は，コア共有後の残余が強く集中することを Collection #1 の $n = 2$–20 全件で示した．各グループの全 PW から抽出したコアと，同一コーパスの固定残余順位を用いる PW 単位評価では，上位 10 候補が全コア PW の 15.6%，$n = 5$・コア長 8–10 層の 28.2–30.5%をカバーした．置換対照は共有が単純な無作為割当では説明しにくいことを示し，LOO は全評価範囲 $n = 3$–20 で条件付き top-10 11.35%（全 fold 分母 1.64%）を示した．同方式が安全な生成法と受け取られうる現状に，再考を促す結果である．

参考文献

[1] E. Stobert and R. Biddle: “The Password Life Cycle: User Behaviour in Managing Passwords,” in Proc. Symp. Usable Privacy and Security (SOUPS), 2014, pp. 243–255.

[2] S. Pearman et al.: “Let’s Go in for a Closer Look: Observing Passwords in Their Natural Habitat,” in Proc. ACM CCS, 2017, pp. 295–310.

[3] 情報処理推進機構：情報セキュリティ読本（六訂版），第 5 章 1 節 3 項，実教出版 (2022). ISBN 978-4-407-36117-9.

[4] 情報処理推進機構：情報セキュリティ読本（七訂版），第 5 章 1 節 3 項，実教出版 (2025). ISBN 978-4-407-36670-9.

[5] A. Das, J. Bonneau, M. Caesar, N. Borisov, and X. Wang: “The Tangled Web of Password Reuse,” in Proc. NDSS, 2014.

[6] B. Pal, T. Daniel, R. Chatterjee, and T. Ristenpart: “Beyond Credential Stuffing: Password Similarity Models Using Neural Networks,” in Proc. IEEE S&P, 2019, pp. 417–434.

[7] T. Hunt: “The 773 Million Record ‘Collection #1’ Data Breach,” Jan. 16, 2019, `https://troyhunt.com/the-773-million-record-collection-1-data-reach/` (accessed 2026-07-27).

[8] D. Wang, Y. Zou, Y.-A. Xiao, S. Ma, and X. Chen: “Pass2Edit: A Multi-Step Generative Model for Guessing Edited Passwords,” in Proc. USENIX Security, 2023, pp. 983–1000.

[9] K. Xiu and D. Wang: “PointerGuess: Targeted Password Guessing Model Using Pointer Mechanism,” in Proc. USENIX Security, 2024, pp. 5555–5572.

[10] B. Ur, F. Noma, J. Bees, S. M. Segreti, R. Shay, L. Bauer, N. Christin, and L. F. Cranor: “I Added ‘!’ at the End to Make It Secure’: Observing Password Creation in the Lab,” in Proc. Symp. Usable Privacy and Security (SOUPS), 2015, pp. 123–140.

[11] 森啓華, シュウ インゴウ, 森達哉：言語圏ごとのパスワード生成・管理の傾向比較，コンピュータセキュリティシンポジウム (CSS) 2018, pp. 530–537 (2018).

[12] M. Weir, S. Aggarwal, B. de Medeiros, and B. Glodek: “Password Cracking Using Probabilistic Context-Free Grammars,” in Proc. IEEE Symp. Security and Privacy (S&P), 2009, pp. 391–405.

[13] D. Wang, Z. Zhang, P. Wang, J. Yan, and X. Huang: “Targeted Online Password Guessing: An Underestimated Threat,” in Proc. ACM CCS, 2016, pp. 1242–1254.

[14] National Institute of Standards and Technology: “Digital Identity Guidelines: Authentication and Authenticator Management,” NIST SP 800-63B-4, 2025.

[15] W3C: “Web Authentication: An API for Accessing Public Key Credentials Level 2,” W3C Recommendation, Apr. 8, 2021.

[16] 倉崎翔大, 金岡晃：辞書攻撃における国や地域のパスワード特性分析，マルチメディア，分散，協調とモバイル (DICOMO) シンポジウム 2022, pp. 271–277 (2022).

[17] 坪根恵, 秋山満昭, 森達哉：高校生を対象としたセキュリティ教育テキストの国際比較調査，コンピュータセキュリティシンポジウム (CSS) 2021, pp. 433–438 (2021).

[18] 宇田川暢：情報漏洩が大学に与えるセキュリティリスク，大学 ICT 推進協議会 年次大会 (AXIES) 2021, TD1-1 (2021).

[19] J. Bonneau: “The Science of Guessing: Analyzing an Anonymized Corpus of 70 Million Passwords,” in Proc. IEEE S&P, 2012, pp. 538–552.

[20] G. Strona, D. Nappo, F. Boccacci, S. Fattorini, and J. San-Miguel-Ayanz: “A Fast and Unbiased Procedure to Randomize Ecological Binary Matrices with Fixed Row and Column Totals,” Nat. Commun., Vol. 5, 4114 (2014).

[21] C. J. Carstens: “Proof of Uniform Sampling of Binary Matrices with Fixed Row Sums and Column Sums for the Fast Curveball Algorithm,” Phys. Rev. E, Vol. 91, 042812 (2015); Erratum, Vol. 94, 039902 (2016).

© 2026 Information Processing Society of Japan

10. 研究倫理

本研究では，公開状態で流通していたメールアドレスとパスワードを含む Collection #1 のうち，前処理後の平文パスワードを分析した．公開状態にあっても本人の同意を得たデータとは考えにくく，実在する個人に結びつき得る機微情報として取り扱った．合成データでは，同一メールグループに複数の漏洩パスワードが紐づく状態とコア共有構造を生成時に仮定するため，これらの脅威条件の実在性を確認できず，経験分布も生成仮定から独立に評価できない．このため，研究目的の達成には実データが必要と判断した．データの性質，操作的定義および解釈上の限界は §3 および §8.3 に示す．

分析対象は，公開媒体上のリンクを通じて Web 上のファイルホスティングサービスから取得したと考えられるが，取得時期，リンクの掲載元および URL を確証する記録は現存しない．非公開フォーラムや P2P ネットワークの利用，当該サービスへの登録・支払い，配布者との連絡・交渉は行っていない．利用条件の表示は記憶になく，取得ファイルにも条件を示す文書はなかったが，研究利用の許諾を意味しない．本研究のための侵入や認証情報の新規収集は行っておらず，取得先を特定し得る情報も掲載しない．分析したコピーが Hunt の報告した MEGA 上の Collection #1[7] と同一かつ未改変であることは確認できない（§8.3）．

本研究は著者の雇用先における職務とは無関係に，業務外の時間と著者個人の機器のみで実施した．著者が確認できる範囲では，本研究に適用可能な雇用先の倫理審査・相談窓口を特定できず，倫理審査または承認は受けていない．論文執筆に際して CSS 2026 研究倫理相談窓口に相談し，その助言を踏まえて実データの必要性，取得経緯，管理方法および危害低減措置を整理した．しかしながら，同相談は倫理審査上の承認または適法性の判断を意味しない．

実在サービスへの認証試行は行わず，生データおよび平文パスワードを含む中間生成物を第三者に提供・再配布していない．データはインターネット側から接続できないアクセス制限されたストレージに保存し，ストレージと解析用 PC へのアクセスを著者本人に限定しており，クラウドには保存していない．原データは manifest を作成して暗号化したオフライン媒体へ移行する予定である．発表後約 1 か月の照会対応期間後，展開済み平文データ，分析用データベースおよび中間生成物は，各段階のハッシュ値を記録して削除する予定である．処理コード，設定，manifest，ハッシュ値および非機微な集計結果は保持し，本研究の検証時には中間生成物を再生成する．原データは検証・訂正および将来研究の可能性のため発表後 3 年間保管し，その後は継続理由と保護措置を記録して再評価し，必要がなければ削除する．新たな研究への利用時には，実データの必要性，代替手段，再利用の相当性，管理方法および公表上の危害を改めて評価する．

パスワード推測への悪用可能性を考慮し，公表内容は研究結果の説明に必要な集計値と，個別の認証情報に結びつかない構造に限定した．メールアドレス，個別パスワードとその対応，メールグループやサービスを特定できる結果，希少なコア・残余，完全な候補順位および生データは公開しない．データセット由来の個別認証情報は例示せず，分析手法と残余テンプレートの例示には合成例のみを用いた．分析コードは一般公開せず，正当な研究・検証目的の要求に対して，生データや実データ由来の候補表等を除いた版の提供を個別に検討する．実データ利用と公表に伴う危害を，条件付き危険性を示して運用の再考を促す公益と比較し，以上の制限を採用した．

© 2026 Information Processing Society of Japan